

Relatório do Trabalho de Grupo

Proposta de Controlo de Acessos para Mini-Servidor Linux

1. Identificação do Grupo

Grupo: Grupo Breakroom 7

Elementos: Ivan Moniz · Joseana Barros · Rogério Dias

Papéis assumidos: Ivan Moniz — Administrador do Sistema | Joseana Barros — Operador Web | Rogério Dias — Auditor

2. Síntese do Cenário

Uma pequena equipa prepara um mini-servidor Linux (Ubuntu, Linode VPS) para alojar uma aplicação web, com quatro perfis distintos de utilizadores: **Administrador do Sistema, Operador Web, Auditor e Visitante Técnico**. Foram identificados **riscos críticos**: partilha de contas, permissões excessivas em pastas do projeto, uso frequente da conta root, acesso SSH sem regras claras, falta de documentação sobre acessos e ficheiros de configuração expostos a utilizadores não autorizados.

A solução proposta aplica o princípio do menor privilégio, separação de funções por grupos Linux, autenticação SSH exclusivamente por chave pública e estrutura de diretórios com permissões granulares. Toda a implementação foi realizada num VPS real com Ubuntu no Linode, com acesso SSH por chave Ed25519.

3. Perfis, Grupos e Responsabilidades

Perfil	Grupo	Responsabilidades	Permissões Necessárias	Permissões a Evitar
Administrador do Sistema	admins	Gerir utilizadores, serviços, atualizações e permissões	sudo completo; leitura/escrita em /etc, /var/log, /home/projeto-web	Login direto como root; acesso desnecessário a dados de outros perfis
Operador Web	webops	Publicar e atualizar ficheiros da aplicação web	Escrita em /home/projeto-web/public; leitura em /docs	Acesso a /config e /logs; uso de sudo
Auditor	auditores	Consultar logs, registos e documentação de evidências	Leitura em /home/projeto-web/logs e /docs	Qualquer escrita no servidor; acesso a /config; sudo
Visitante Técnico	visitantes	Consultar apenas documentação pública autorizada	Leitura em /home/projeto-web/docs	Acesso a qualquer outra pasta; SSH ao servidor

4. Estrutura de Diretórios Proposta

A estrutura foi criada em `/home/projeto-web/` no VPS (movida de `/opt/` para facilitar a gestão com o utilizador `adminuser` como dono):

```
/home/projeto-web/  
— public/ → ficheiros HTML, CSS, JS e imagens da aplicação web  
— config/ → ficheiros de configuração, credenciais e variáveis de ambiente  
— logs/ → registos de acesso, erros e eventos da aplicação  
— docs/ → documentação técnica e manuais autorizados
```

Diretório	Pode Ler	Pode Escrever	Sem Acesso	Risco se Excessivo
/public	webops, auditores, visitantes	webops	—	Exposição de ficheiros internos se mal configurado
/config	admins	admins	webops, auditores, visitantes	Exposição de passwords e chaves de API
/logs	admins, auditores	admins (sistema)	webops, visitantes	Fuga de informação sensível sobre utilizadores
/docs	todos os perfis	admins	—	Publicação inadvertida de documentos internos

5. Proposta de Permissões

Caminho	Dono / Grupo	Permissão	Justificação
/home/projeto-web/	adminuser / admins	750 (drwxr-x—)	Raiz do projeto; adminuser é dono total; só admins entram
/home/projeto-web/public/	adminuser / webops	775 (drwxrwxr-x)	Webops precisam escrever para publicar; leitura geral
/home/projeto-web/config/	adminuser / admins	750 (drwxr-x—)	Ficheiros críticos; apenas admins acedem; nenhum outro grupo
/home/projeto-web/logs/	adminuser / auditores	750 (drwxr-x—)	Auditores lêem; escrita apenas pelo sistema/admins
/home/projeto-web/docs/	adminuser / visitantes	755 (drwxr-xr-x)	Documentação pública; todos lêem; só adminuser escreve
/home/projeto-web/config/*	adminuser / admins	640 (-rw-r—)	Ficheiros individuais: dono lê/escreve, grupo só lê

Comandos utilizados no VPS

```
# Criar grupos
sudo groupadd admins && sudo groupadd webops
sudo groupadd auditores && sudo groupadd visitantes

# Criar utilizadores
sudo useradd -m -s /bin/bash -G admins,sudo adminuser
sudo useradd -m -s /bin/bash -G webops webuser
sudo useradd -m -s /bin/bash -G auditores auditor1
sudo useradd -m -s /usr/sbin/nologin -G visitantes visitor1

# Criar estrutura e aplicar permissões
sudo mkdir -p /home/projeto-web/{public,config,logs,docs}
sudo chown adminuser:admins /home/projeto-web/ && sudo chmod 750 /home/projeto-web/
sudo chown adminuser:webops /home/projeto-web/public && sudo chmod 775 /home/projeto-web/public
sudo chown adminuser:admins /home/projeto-web/config && sudo chmod 750 /home/projeto-web/config
sudo chown adminuser:auditores /home/projeto-web/logs && sudo chmod 750 /home/projeto-web/logs
sudo chown adminuser:visitantes /home/projeto-web/docs && sudo chmod 755 /home/projeto-web/docs
```

6. Regras de Acesso Remoto por SSH

Perfil	Acesso SSH?	Autenticação	Justificação
Administrador	Sim	Chave SSH Ed25519; MFA recomendado	Necessita acesso remoto para gestão; nunca usar password
Operador Web	Sim (restrito)	Chave SSH; SFTP/rsync apenas para /public	Publicação de ficheiros; sem shell completa (ForceCommand)
Auditor	Sim (leitura)	Chave SSH; shell restrita (rbash)	Consulta remota de logs; sem capacidade de modificar
Visitante Técnico	Não	—	Acesso apenas via portal web; SSH desnecessário e inseguro

Configurações aplicadas em /etc/ssh/sshd_config

Diretiva	Valor
PermitRootLogin	não
PasswordAuthentication	não
PubkeyAuthentication	sim
AllowGroups	admins webops auditores
MaxAuthTries	3
LoginGraceTime	30
ClientAliveInterval / ClientAliveCountMax	300 / 2

O que nunca publicar como evidência: chaves privadas SSH, conteúdo de `/etc/shadow`, passwords em texto claro, tokens de API ou credenciais de bases de dados.

7. Riscos e Medidas de Mitigação

Risco	Impacto	Medida de Mitigação
Partilha da mesma conta entre utilizadores	Impossibilidade de rastrear ações; comprometimento total se exposta	Contas individuais para cada utilizador; desativar contas genéricas
Permissões excessivas em <code>/config</code>	Exposição de credenciais, chaves de API e configurações críticas	<code>chmod 750</code> em <code>/config</code> ; acesso apenas ao grupo <code>admins</code> ; auditoria regular
Uso frequente da conta <code>root</code>	Qualquer erro ou comprometimento afeta todo o sistema	<code>PermitRootLogin</code> não no SSH; usar <code>sudo</code> com log (<code>/var/log/auth.log</code>)
SSH sem autenticação por chave	Ataques de força bruta a passwords; acesso não autorizado	<code>PasswordAuthentication</code> não; usar apenas chaves <code>Ed25519</code> ; <code>fail2ban</code>
Falta de documentação de acessos	Dificuldade em auditar e responder a incidentes	Manter registo atualizado de utilizadores, grupos e permissões
Logs acessíveis a operadores ou visitantes	Fuga de informação sobre utilizadores e falhas do sistema	<code>chmod 750</code> em <code>/logs</code> ; acesso restrito a <code>admins</code> e auditores
Sem limite de tentativas SSH	Ataques de força bruta bem-sucedidos	<code>MaxAuthTries 3</code> ; <code>fail2ban</code> ; porta SSH não-padrão

8. Conclusão

O grupo implementou uma solução de controlo de acessos num VPS real Ubuntu (Linode), baseada em quatro princípios fundamentais: separação de funções (cada perfil tem um grupo Linux dedicado), menor privilégio (nenhum utilizador tem mais permissões do que as necessárias), autenticação forte (SSH exclusivamente por chave pública `Ed25519`, sem login `root` direto) e rastreabilidade (contas individuais permitem auditoria completa).

A estrutura de diretórios em `/home/projeto-web/` isola os ficheiros críticos de configuração (`/config` com `chmod 750`) do acesso geral. Os registos (`/logs`) ficam acessíveis apenas a auditores e administradores. As regras SSH configuradas no `sshd_config` reduzem significativamente a superfície de ataque remoto.

As principais decisões foram: criar contas individuais (`adminuser`, `webuser`, `auditor1`, `visitor1`); aplicar `chmod 750` em `/config` e `/logs`; desativar autenticação por password no SSH; proibir login direto como `root`; e documentar todas as permissões. A implementação foi verificada com testes reais de acesso (`sudo -u`) que confirmaram o funcionamento correto das restrições.